Password and Authentication Policy

Policy ID: IT-SEC-001 | Version 3.2 | Owner: Information Security | Effective: 1 March 2026

1. Purpose and Scope

This policy sets the rules for passwords, multi-factor authentication and account lockout for every Kestrel Analytics account: employee, contractor and service accounts, on company-managed and personal devices. It applies to the Kestrel single sign-on (SSO) directory and to any application that cannot use SSO.

2. Password Requirements

- Minimum length is 14 characters. Passphrases of four or more unrelated words are encouraged.
- There are no composition rules (no forced symbols or digits), but every new password is checked against a list of breached and commonly used passwords.
- Passwords do not expire on a schedule. You must change a password only when there is evidence or suspicion that it has been compromised.
- Your last 10 passwords cannot be reused.
- Never reuse your Kestrel password on a personal or third-party website.

3. Multi-Factor Authentication

Multi-factor authentication (MFA) is required for SSO, email, the VPN and every application that holds Internal or higher data.

- Approved methods are the Microsoft Authenticator app with number matching, and FIDO2 security keys.
- SMS and voice codes are not allowed, except as a temporary fallback issued by the Service Desk for at most 7 days while a replacement device is set up.
- If you receive an MFA prompt you did not start, deny it and report it as a Security Incident (see IT-SEC-008).
- If you lose the phone that holds your authenticator, the Service Desk can issue a Temporary Access Pass, valid for 8 hours, so you can register a new device.

4. Account Lockout

After 10 failed sign-in attempts within 15 minutes, the account is locked for 30 minutes and then unlocks automatically. To unlock it sooner, contact the Service Desk. Before unlocking an account or resetting a password, the agent must verify your identity by video call with your company ID badge, or by confirmation from your line manager. Agents must never unlock an account based only on an email or chat message.

5. Password Managers

1Password Business is the only approved password manager for work credentials, and every employee receives a licence at onboarding. Saving work passwords in browser password stores (Chrome, Edge or Safari) is not allowed. Shared team credentials must be kept in a 1Password shared vault owned by a named person, never in documents, spreadsheets or chat messages.

6. Privileged Accounts

Administrators receive a separate admin account with the prefix adm- (for example adm-jdoe). It is used only for administrative tasks, never for email or web browsing.

- Admin account passwords must be at least 20 characters long.
- A FIDO2 hardware security key is mandatory. The company issues two YubiKey 5 keys: a primary and a backup.
- Admin accounts are reviewed every quarter and are disabled after 45 days without use.

7. Compromised Credentials

If you think a password or MFA device has been compromised, report it within 1 hour by raising a ticket in the Security Incident category or by calling the security hotline on ext. 7100. The Service Desk will force a password reset, sign you out of all sessions and remove your MFA registrations. Do not wait until you are sure: a false alarm costs nothing.